

Task 2 Governance Responsibility and Authority Matrix (20 marks)

1. Cross Functional Governance Responsibility Matrix

Legend

- **A = Accountable**
- **R = Responsible**
- **C = Consulted**
- **I = Informed**

Activity	Board	CEO	CISO	CRO	Legal/ compliance	Finance	HR	IT
Approve cyber risk appetite	A	R	C	C	C	I	I	I
Develop security strategy	I	A	R	C	C	C	C	I
Approve security policies	I	A	A	C	C	I	C	I
Maintain enterprise cyber risk register	I	A	A	R	C	I	I	I
Accept cybersecurity risks	A	A	C	R	C	C	I	C
Implement security controls	I	I	A	C	I	I	I	R
Manage security incidents	I	A	R	C	C	I	C	R
Approve security investments	C	A	C	C	I	R	I	C
Monitor regulatory compliance	I	A	C	C	R	I	I	C
Deliver security awareness programme	I	A	R	I	C	I	R	C

2. Role Profiles / Responsibility Cards

Role Profile 1: Board of Directors

Purpose

Provide strategic management and ensure cybersecurity risks are managed according to organisational

objectives and risk appetite.

Key Governance Responsibilities

- Approve cybersecurity risk appetite.
- Provide oversight of enterprise cyber risk exposure.
- Review significant security incidents.
- Ensure management accountability for cybersecurity.
- Challenge executive decisions involving material cyber risks.

Decision Authority

- Approve enterprise risk appetite.
- Approve major risk acceptance decisions.
- Request remediation actions from executives.
- Hold executive leadership accountable.

Reporting Obligations

Receives:

- Quarterly cybersecurity risk reports.
- Major incident updates.
- Security maturity assessments.
- Regulatory compliance updates.

Performance Indicators

KPI	Measurement
Board cyber risk reporting completion	Percentage of scheduled reports delivered
Critical risk oversight effectiveness	Percentage of high risks with executive ownership and treatment plans
Cybersecurity governance maturity	Annual maturity assessment score

Role Profile 2: Chief Executive Officer (CEO)

Purpose

Provide executive ownership of cybersecurity and ensure security decisions support business strategy.

Key Governance Responsibilities

- Establish executive accountability for security.
- Approve security strategy and major investments.
- Resolve business-security conflicts.
- Ensure adequate resources are available.

Decision Authority

- Final authority for business risk acceptance.
- Approves security investments.
- Assigns executive ownership for major risks.

Reporting Obligations

Receives:

- CISO security reports.
- Enterprise risk updates.
- Incident impact assessments.

Performance Indicators

KPI	Measurement
Cyber risk treatment completion	Percentage of executive-owned risks remediated
Major incident response effectiveness	Time taken to coordinate executive response

Role Profile 3: Chief Information Security Officer (CISO)**Purpose**

Lead cybersecurity governance, strategy and security risk management across TechGlobal.

Key Governance Responsibilities

- Develop cybersecurity strategy.
- Maintain security policies and standards.
- Manage cyber risk reporting.
- Chair Security Governance Committee.
- Coordinate incident response governance.
- Provide security guidance to business units.

Decision Authority

- Define security standards.
- Escalate unacceptable security risks.
- Approve security architecture requirements.
- Recommend risk treatment actions.

Reporting Obligations

Reports to:

- CEO

Provides reports to:

- Board Risk Committee
- Security Governance Committee

Performance Indicators

KPI	Measurement
Security control effectiveness	Percentage of critical controls operating effectively
Risk remediation performance	Percentage of cyber risks closed within agreed timelines
Security maturity improvement	Progress against security roadmap

Role Profile 4: Chief Risk Officer (CRO) / Risk Function

Purpose

Integrate cybersecurity risks into enterprise risk management.

Key Governance Responsibilities

- Maintain enterprise risk methodology.
- Challenge security risk assessments.
- Validate risk ratings.
- Monitor risk treatment progress.
- Support risk reporting.

Decision Authority

- Approve risk assessment methodology.
- Challenge inappropriate risk acceptance.
- Escalate unmanaged enterprise risks.

Reporting Obligations

Receives:

- Cyber risk register.
- Security metrics.

- Risk treatment updates.

Reports:

- Enterprise risk position to executive management.

Performance Indicators

KPI	Measurement
Cyber risk reporting accuracy	Accuracy and completeness of risk reporting
Risk review completion	Percentage of risks reviewed within cycle
Risk treatment effectiveness	Reduction in overdue risks

Role Profile 5: Legal / Compliance

Purpose

Ensure security governance aligns with legal obligations, contracts and regulatory requirements.

Key Governance Responsibilities

- Interpret cybersecurity regulations.
- Advise on privacy requirements.
- Review contractual security obligations.
- Support incident notification decisions.

Decision Authority

- Provide legal approval on regulatory matters.
- Determine notification obligations.
- Approve compliance interpretations.

Reporting Obligations

Receives:

- Security incidents.
- Compliance assessments.
- Regulatory risk reports.

Performance Indicators

KPI	Measurement
-----	-------------

Regulatory compliance rate	Percentage of obligations fulfilled
Legal review completion	Timeliness of regulatory assessments
Incident notification accuracy	Compliance with reporting requirements

Role Profile 6: Finance

Purpose

Ensure cybersecurity investments align with financial governance principles.

Key Governance Responsibilities

- Evaluate security investment proposals.
- Monitor security budgets.
- Assess financial impact of cyber risks.
- Support cyber insurance decisions.

Decision Authority

- Approve budget allocation within financial authority.
- Challenge unsupported investment requests.

Reporting Obligations

Receives:

- Security investment plans.
- Cyber loss estimates.
- Cost-benefit analysis.

Performance Indicators

KPI	Measurement
Security budget utilisation	Percentage of approved budget effectively used
Financial risk visibility	Accuracy of cyber cost reporting
Investment value tracking	Benefits achieved from security investments

Role Profile 7: Human Resources (HR)

Purpose

Manage human related security risks and promote security culture.

Key Governance Responsibilities

- Manage employee security awareness.
- Support joiner/mover/leaver controls.
- Manage disciplinary processes.
- Promote security culture.

Decision Authority

- Approve HR security processes.
- Enforce employee security requirements.

Reporting Obligations

Receives:

- Awareness metrics.
- Employee security incidents.
- Access lifecycle reports.

Performance Indicators

KPI	Measurement
Security training completion	Percentage of employees completing training
Access lifecycle effectiveness	Timeliness of employee access changes
Security culture improvement	Employee awareness assessment results

Role Profile 8: Information Technology (IT)

Purpose

Implement and operate secure technology services.

Key Governance Responsibilities

- Deploy security controls.
- Maintain infrastructure security.
- Manage vulnerabilities.
- Support incident response.
- Implement approved security standards.

Decision Authority

- Technical implementation decisions.
- Operational security changes within approved standards.

Reporting Obligations

Reports:

- Control performance.
- Vulnerability status.
- Operational incidents.

Performance Indicators

KPI	Measurement
Vulnerability remediation rate	Percentage of vulnerabilities fixed within SLA
System security compliance	Percentage of systems meeting security standards
Service availability	Technology availability and resilience

3. Conflict Resolution Note**Conflict Area 1: IT Director vs CISO Security Authority****Potential Conflict**

IT may prioritise availability, delivery speed and operational efficiency, while the CISO focuses on security risk reduction.

Resolution Approach

- CISO owns security standards and risk decisions.
- IT owns implementation and operational delivery.
- Conflicts are escalated to the Security Governance Committee.
- The CEO makes final business risk decisions where trade-offs remain.

Conflict Area 2: Business Growth vs Security Requirements

Potential Conflict

Business units may request faster product releases or reduced controls to meet commercial objectives.

Resolution Approach

- Business leaders own operational risks.
- CISO provides security impact assessment.
- CRO evaluates enterprise risk implications.
- The CEO approves exceptions involving significant business risk.

Conflict Area 3: Legal Compliance vs Business Operations

Potential Conflict

Legal may require additional controls due to regulatory obligations while business teams prioritise operational flexibility.

Resolution Approach

- Legal determines regulatory requirements.
- CISO translates obligations into security controls.
- Business owners implement approved solutions.
- Material compliance risks are escalated to executive leadership.

Governance Resolution Principles

TechGlobal should apply the following principles:

1. Business owners remain responsible for risks affecting their operations.
2. Security governance should challenge technology and business decisions when necessary.
3. Operational risks stay with managers, material risks escalate to executives.
4. Security decisions should rely on risk assessments, business impact and regulatory requirements.
5. Conflicts should be resolved through governance forums, not informal agreements.